

Contoso - Legal Review Playbook

Document ID: AC-LEGAL-PLB-2024-001 **Version:** 2.4 **Effective Date:** January 1, 2024 **Last Reviewed:** November 30, 2023 **Owner:** General Counsel, Legal Affairs **Classification:** Internal - Confidential

1. Purpose

This playbook provides a standardized framework for legal review of all contracts entered into by Contoso. It ensures consistent evaluation, risk identification, and compliance with Contoso's Corporate Procurement Policy (AC-PROC-POL-2024-001).

All legal reviewers must follow this playbook when conducting contract reviews. Deviations must be documented and approved by the Senior Legal Counsel.

2. Clause-by-Clause Review Checklist

2.1 Identification & Parties (Items 1-3)

#	Review Item	Standard	Action if Non-Compliant
1	Party identification	Full legal name, jurisdiction of incorporation, and address for each party. Verify against corporate registry.	Request correction; do not proceed without verified legal names.
2	Authority to contract	Signatory has authority per approval matrix (AC-PROC-POL S2). Verify against delegation of authority register.	Obtain proper authorization before execution.
3	Effective date & term	Clearly stated start date, initial term, and renewal provisions. Term must align with business case.	Clarify with counterparty; flag if term exceeds 5 years without SVP approval.

2.2 Scope & Commercial Terms (Items 4-8)

#	Review Item	Standard	Action if Non-Compliant
4	Scope of services/deliverables	Detailed description of services, deliverables, milestones, and acceptance criteria. Attached SOW for complex engagements.	Request detailed SOW; vague scope = scope creep risk.
5	Pricing & payment terms	Fixed pricing preferred. Payment terms per AC-PROC-POL S5. Currency in USD unless approved.	Flag deviations; recalculate if terms don't match policy.
6	Price adjustment mechanisms	CPI-based only. No unilateral increases. Annual cap of 3% unless tied to specific index.	Reject unilateral increase rights; propose CPI cap.

7	Service levels (SLAs)	Measurable KPIs with remedies (service credits, termination right) for persistent failure.	Request SLA schedule if missing; minimum 95% uptime for technology services.
8	Change management	Written change order process with Contoso approval required. Pricing impact disclosed before approval.	Insert standard change order clause if missing.

2.3 Risk Allocation (Items 9-14)

#	Review Item	Standard	Action if Non-Compliant
9	Indemnification	Per AC-PROC-POL S3.1. Mutual with enhanced vendor obligations for IP, data, and misconduct.	Redline to conform to standard. Major risk if vendor indemnification is weak or absent.
10	Limitation of liability	Per AC-PROC-POL S3.2. Cap $\geq$ 2x annual value or \$1M. Mandatory uncapped carve-outs.	Reject caps below 1x annual value. Reject any unlimited Contoso liability.
11	Insurance requirements	Per AC-PROC-POL S6. Minimums by contract type. Contoso named as additional insured.	Request insurance certificates before execution. Flag deficiencies.
12	Warranties & representations	Vendor warrants: authority, compliance with laws, non-infringement, professional standards. Survival period $\geq$ 2 years.	Add missing warranties. Flag "as-is" disclaimers - unacceptable for services > \$50K.
13	Force majeure	Per AC-PROC-POL S3.6. Include enterprise-specific events. 90-day termination right.	Insert standard clause if missing. Enterprise events are non-negotiable.
14	Assignment & subcontracting	Contoso consent required for assignment or material subcontracting. Contoso may assign freely within corporate group.	Reject vendor right to assign without consent. Flag subcontracting without oversight.

2.4 Intellectual Property & Data (Items 15-18)

#	Review Item	Standard	Action if Non-Compliant
15	IP ownership	Per AC-PROC-POL S3.3. Custom work = Contoso owned. Pre-existing IP = licensed.	Reject vendor ownership of custom deliverables. Major risk flag.
16	Confidentiality	Per AC-PROC-POL S3.4. 5-year survival. Return/destruction obligation.	Insert standard clause if missing. Critical - cannot proceed without.
17	Data protection & privacy	Per AC-PROC-POL S3.7. Data Privacy Regulation/Regional Privacy Regulation	Involve Privacy Office. Do not approve without privacy

		compliance. domestic-only storage default.	compliance review.
18	Data handling upon termination	Vendor must return all Contoso data within 30 days of termination and certify destruction of copies.	Add if missing. Retention of Contoso data post-termination is unacceptable.

2.5 Termination & Dispute Resolution (Items 19-22)

#	Review Item	Standard	Action if Non-Compliant
19	Termination for convenience	Contoso right to terminate with 30-90 days' notice. Payment only for services rendered.	Must be present. Absence is a Major risk flag.
20	Termination for cause	30-day cure period. Immediate termination for data breach, safety, insolvency, or material misconduct.	Ensure all immediate termination triggers are present.
21	Transition assistance	Required for contracts > \$250K. 90-day minimum at vendor's then-current rates.	Add for qualifying contracts. Absence creates operational risk.
22	Governing law & dispute resolution	Per AC-PROC-POL S3.8. New York State law; the designated forum arbitration.	Reject foreign governing law without General Counsel approval.

2.6 Compliance & Regulatory (Items 23-26)

#	Review Item	Standard	Action if Non-Compliant
23	Regulatory compliance	Vendor represents compliance with all applicable laws, including enterprise regulations where relevant.	Must include. Especially critical for on-site or safety-related services.
24	Anti-corruption & sanctions	Vendor represents compliance with applicable anti-corruption laws, applicable anti-bribery laws, and sanctions regimes.	Must include for international vendors and contracts > \$100K.
25	Tax compliance	Per AC-PROC-POL S8. Proper tax registrations, invoicing standards, withholding obligations addressed.	Involve Tax department for cross-border contracts > \$50K.
26	Cybersecurity	Per AC-PROC-POL S7. SOC 2, ISO 27001, encryption, MFA, incident response requirements.	Must include for technology vendors. Involve CISO for critical systems.

3. Risk Classification Criteria

3.1 Risk Levels

Risk Level	Definition	Action Required	Approval to Proceed
------------	------------	-----------------	---------------------

Major	Material deviation from policy; significant financial, legal, or operational exposure. Could result in regulatory penalties, litigation, or material loss.	Must be resolved before execution. If counterparty refuses, escalate to General Counsel.	General Counsel
Moderate	Notable deviation from standard terms; manageable but increased risk. May require monitoring or compensating controls.	Negotiate resolution. May proceed with documented risk acceptance.	Senior Legal Counsel + Business Owner VP
Minor	Administrative or stylistic deviation. Low risk impact.	Note in review summary. Recommend correction if practical.	Reviewing Counsel

3.2 Automatic Major Risk Triggers

The following automatically classify a contract as Major risk, regardless of other factors:

1. **Unlimited liability for Contoso** - Prohibited per policy.
2. **Missing indemnification clause** - Unacceptable exposure.
3. **Auto-renewal exceeding 3 years** - Prohibited without EVP/CFO approval.
4. **Foreign governing law without approval** - Enforceability concerns.
5. **Missing termination for convenience** - Operational lock-in.
6. **Vendor IP ownership of custom deliverables** - Loss of Contoso assets.
7. **Missing data protection provisions** (contracts involving personal data) - Regulatory risk.
8. **Missing cybersecurity requirements** (technology contracts) - Security exposure.
9. **Exclusive dealing without CEO approval** - Anti-competitive risk.
10. **Payment to sanctioned jurisdictions** - Legal prohibition.

3.3 Automatic Moderate Risk Triggers

1. Missing force majeure clause.
2. Non-standard payment terms (deviation from policy by > 30 days).
3. Weak or vague indemnification language.
4. Missing insurance requirements or below-minimum coverage.
5. Vague IP ownership provisions.
6. Absence of SLAs for service contracts.
7. Non-standard limitation of liability (within policy range but below recommended).
8. Missing or inadequate transition assistance provisions.
9. Term exceeding 3 years without renewal checkpoints.
10. Missing change management procedures.

3.4 Risk Scoring

Factor	Weight	Scoring
Financial exposure	30%	Based on contract value and liability terms
Operational dependency	25%	Based on criticality to Contoso operations
Regulatory/compliance	20%	Based on applicable regulatory requirements
Counterparty risk	15%	Based on vendor financial stability and track record

Reputational	10%	Based on public-facing nature and ESG considerations
--------------	-----	--

Total score >= 70: Major risk. Score 40-69: Moderate risk. Score < 40: Minor risk.

4. Template Deviation Handling

4.1 Deviation Categories

Category	Description	Handling
Category A - Pre-Approved	Changes to business-specific details (names, dates, scope, pricing within parameters)	Reviewer may approve without escalation
Category B - Standard Negotiation	Changes to non-material terms (notice periods within range, minor warranty adjustments)	Reviewer may approve; document rationale
Category C - Material Deviation	Changes to risk allocation, mandatory clauses, or liability provisions	Requires Senior Legal Counsel approval
Category D - Policy Exception	Changes that conflict with AC-PROC-POL requirements	Requires General Counsel approval per policy S12

4.2 Deviation Documentation

All Category C and D deviations must be documented using the Contract Deviation Form (AC-LEGAL-FORM-003), which includes:

- Clause reference and standard language
- Proposed deviation and counterparty rationale
- Risk assessment
- Mitigating factors or compensating controls
- Recommendation (accept/reject/alternative)
- Approval signature

4.3 Deviation Tracking

All deviations are logged in the Contract Deviation Register (SharePoint) for:

- Trend analysis (identifying frequently negotiated clauses)
- Vendor intelligence (tracking counterparty negotiation patterns)
- Policy improvement (identifying clauses that may need updating)

5. Escalation Paths

5.1 Standard Escalation

Reviewing Counsel

-> (Major risk or policy conflict)

Senior Legal Counsel

-> (Unresolved Major risk or cross-functional impact)

Deputy General Counsel

-> (Enterprise risk, regulatory concern, or precedent-setting)

General Counsel

-> (Board-level concern or litigation risk)

CEO / Board (via General Counsel)

5.2 Specialized Escalation

Issue	Primary Escalation	Secondary Escalation
Privacy/data protection	Chief Privacy Officer	General Counsel
Cybersecurity	CISO	CTO + General Counsel
Tax compliance	VP Tax	CFO
Enterprise safety/regulatory	VP Safety	SVP Operations + General Counsel
Insurance adequacy	VP Risk Management	CFO
Anti-corruption/sanctions	Chief Compliance Officer	General Counsel
Competition law	External competition counsel	General Counsel
Environmental/ESG	VP Sustainability	SVP Corporate Affairs

5.3 Emergency Escalation

For time-critical matters (e.g., safety issues, active data breaches, regulatory deadlines):

- Direct escalation to General Counsel or Deputy General Counsel.
- After-hours contact via Legal Emergency Hotline.
- Document the emergency escalation within 24 hours.

6. Common Red Flags with Examples

6.1 Financial Red Flags

Red Flag	Example	Risk Level
Unlimited liability for Contoso	"Client shall be liable for all damages without limitation."	Major
Excessive advance payments	"50% of total contract value due upon signing."	Major
Unrestricted price increases	"Provider may adjust fees at any time upon 30 days' notice."	Major
Payment terms < Net 30	"Payment due within 15 days of invoice."	Moderate
Most-favored pricing absent	Large contracts without price matching clause.	Minor

6.2 Liability & Risk Red Flags

Red Flag	Example	Risk Level
Vendor liability cap below 1x	"\$500,000 cap on a \$2M annual contract."	Major

Missing indemnification	Agreement contains no indemnification section.	Major
One-sided indemnification	"Client shall indemnify Provider against all claims." Only Contoso indemnifies.	Major
Missing consequential damages carve-outs	Broad exclusion of all consequential damages with no exceptions.	Moderate
Short warranty period	"Warranties expire 30 days after delivery."	Moderate

6.3 Operational Red Flags

Red Flag	Example	Risk Level
No termination for convenience	Agreement can only be terminated for cause.	Major
Auto-renewal > 3 years	"Agreement automatically renews for successive 5-year terms."	Major
Exclusive dealing	"Client shall not engage any other provider for similar services."	Major
No transition assistance	No provisions for transition upon termination of \$1M+ contract.	Moderate
Unrestricted subcontracting	"Provider may subcontract any obligations without notice."	Moderate

6.4 IP & Data Red Flags

Red Flag	Example	Risk Level
Vendor owns custom deliverables	"All work product shall be the sole property of Provider."	Major
No data return/destruction	No provision for return of Contoso data after termination.	Major
Data stored outside the domestic jurisdiction	"Data may be processed in any Provider facility globally."	Major
Missing breach notification	No requirement for vendor to notify of security incidents.	Major
Vague IP provisions	"Ownership of deliverables shall be determined on a case-by-case basis."	Moderate

6.5 Regulatory Red Flags

Red Flag	Example	Risk Level
----------	---------	------------

Missing Data Privacy Regulation compliance	Contract involving personal data with no privacy provisions.	Major
Foreign governing law	"This agreement shall be governed by the laws of Delaware."	Major
Missing anti-corruption provisions	International contract with no applicable anti-corruption laws/anti-bribery clause.	Moderate
Missing cybersecurity standards	Technology contract with no SOC 2/ISO 27001 requirement.	Major
No regulatory compliance warranty	Vendor does not warrant compliance with applicable laws.	Moderate

7. Approved Language for Key Clauses

7.1 Limitation of Liability - Standard

Limitation of Liability. Except for the Excluded Claims (defined below), neither Party's aggregate liability under this Agreement shall exceed the greater of (a) two (2) times the total fees paid or payable to Provider in the twelve (12) month period immediately preceding the event giving rise to the claim, or (b) One Million domestic Dollars (USD \$1,000,000). "Excluded Claims" means: (i) Provider's indemnification obligations for intellectual property infringement; (ii) either Party's breach of its confidentiality obligations; (iii) Provider's obligations with respect to data breaches or unauthorized disclosure of Contoso data; and (iv) either Party's gross negligence or willful misconduct. Excluded Claims shall not be subject to any limitation of liability.

7.2 Indemnification - Standard

Indemnification. Provider shall defend, indemnify, and hold harmless Contoso, its affiliates, and their respective officers, directors, employees, and agents from and against any and all claims, damages, losses, liabilities, costs, and expenses (including reasonable legal fees) arising out of or relating to: (a) Provider's breach of this Agreement; (b) Provider's negligence or willful misconduct; (c) any claim that the Services or Deliverables infringe any third-party intellectual property right; (d) Provider's violation of applicable laws; or (e) any unauthorized access to, or breach of, Contoso's data in Provider's possession or control. Contoso shall indemnify Provider against claims arising from Contoso's gross negligence or willful misconduct, or Contoso's breach of this Agreement, subject to the limitation of liability set forth herein.

7.3 Confidentiality - Standard

Confidentiality. Each Party (as "Receiving Party") shall maintain in strict confidence all Confidential Information received from the other Party (as "Disclosing Party") and shall not disclose such information to any third party without the Disclosing Party's prior written consent, except to the Receiving Party's employees, agents, or subcontractors who have a need to know and are bound by obligations of confidentiality no less restrictive than those set forth herein. The Receiving Party shall protect Confidential Information using the same degree of care it uses for its own confidential information, but in no event less than reasonable care. These obligations shall survive for five (5) years following termination or expiration of this Agreement, or indefinitely with respect to trade secrets. Upon termination, the Receiving Party shall, at the Disclosing Party's option, return or destroy all Confidential Information and certify such return or destruction in writing within thirty (30) days.

7.4 Termination for Convenience - Standard

Termination for Convenience. Contoso may terminate this Agreement, in whole or in part, at any time and for any reason by providing [30/60/90] days' prior written notice to Provider. Upon such termination, Contoso shall pay Provider for all Services satisfactorily performed and expenses properly incurred through the effective date of termination. Provider shall not be entitled to any lost profits, anticipated fees, or other compensation beyond payment for Services actually rendered.

7.5 Force Majeure - Standard (Enterprise-Specific)

Force Majeure. Neither Party shall be liable for any failure or delay in performance resulting from events beyond its reasonable control, including but not limited to: natural disasters, epidemics or pandemics, acts of government, war, terrorism, civil unrest, strikes or labour disputes, fire, flood, earthquake, interruption of transportation, regulatory authority directives, facility closures, or cybersecurity incidents affecting critical infrastructure ("Force Majeure Event"). The affected Party shall (a) notify the other Party in writing within five (5) business days of becoming aware of the Force Majeure Event, (b) use commercially reasonable efforts to mitigate the impact, and (c) resume performance as soon as reasonably practicable. If a Force Majeure Event continues for more than ninety (90) consecutive days, either Party may terminate this Agreement upon written notice without penalty.

7.6 Governing Law - Standard

Governing Law and Dispute Resolution. This Agreement shall be governed by and construed in accordance with the laws of the State of New York and the federal laws of the domestic jurisdiction applicable therein, without regard to conflict of laws principles. Any dispute arising out of or in connection with this Agreement shall be resolved first through good-faith negotiation between senior representatives of each Party for a period of thirty (30) days. If unresolved, the dispute shall be submitted to mediation in accordance with the American Arbitration Association (AAA) mediation rules. If mediation is unsuccessful within sixty (60) days, the dispute shall be finally resolved by arbitration under the AAA arbitration rules, with the seat of arbitration in the designated forum, New York State. The language of arbitration shall be the language mutually agreed upon by the Parties. Notwithstanding the foregoing, either Party may seek injunctive or other equitable relief from the competent state court.

7.7 Cybersecurity - Standard (Technology Vendors)

Cybersecurity Requirements. Provider shall maintain and comply with industry-standard information security practices, including at a minimum: (a) current SOC 2 Type II certification (or equivalent); (b) ISO 27001 certification for data processing operations; (c) encryption of Contoso data using AES-256 (or equivalent) at rest and TLS 1.2 or higher in transit; (d) multi-factor authentication for all personnel accessing Contoso systems or data; (e) annual third-party penetration testing, with results provided to Contoso upon request; (f) remediation of critical vulnerabilities within seventy-two (72) hours and high-severity vulnerabilities within thirty (30) days of identification; (g) a documented incident response plan with notification to Contoso within twenty-four (24) hours of any security incident involving Contoso data; and (h) storage of all Contoso data within the domestic jurisdiction, unless otherwise approved in writing by Contoso's Chief Information Security Officer.

8. Review Workflow & Documentation

8.1 Standard Review Process

1. **Intake:** Contract submitted via Legal Review Request form (IT Service Management Platform) with supporting documents.
2. **Triage:** Legal Operations assigns reviewer based on contract type, value, and complexity within 1 business day.
3. **Preliminary review:** Reviewer conducts checklist review (Section 2) and risk classification (Section 3) within SLA timeline.
4. **Redlining:** Reviewer prepares redline with comments referencing this playbook and AC-PROC-POL.

5. **Internal review:** For Major risk items, Senior Legal Counsel reviews and approves redline.
6. **Negotiation support:** Reviewer supports business team through negotiation rounds.
7. **Final review:** Reviewer confirms all issues resolved or properly documented/accepted.
8. **Approval:** Reviewer provides legal sign-off; routes for execution per approval matrix.
9. **Filing:** Executed contract filed in Document Management System with metadata tags.

8.2 Documentation Requirements

Every legal review must produce:

- **Review Summary** (AC-LEGAL-FORM-001): One-page summary of key terms, risk classification, and issues.
 - **Redline** (tracked changes): All proposed changes with explanatory comments.
 - **Deviation Log** (if applicable): Per Section 4.2.
 - **Risk Acceptance Form** (if applicable, AC-LEGAL-FORM-002): For any accepted Major or Moderate risk items.
-

9. Post-Execution Monitoring

9.1 Key Date Tracking

Legal Operations maintains a calendar of:

- Contract expiry dates (alerts at 180, 120, and 60 days).
- Renewal option exercise dates.
- Insurance certificate renewal dates.
- Compliance certification renewal dates (SOC 2, ISO 27001).
- SLA review periods.

9.2 Compliance Spot Checks

Legal conducts quarterly spot checks on a sample of active contracts to verify:

- Vendor compliance with cybersecurity requirements.
 - Insurance certificates are current.
 - SLAs are being monitored and enforced.
 - Change orders are properly documented.
-

This playbook is reviewed semi-annually by the Legal Affairs team. Feedback and questions should be directed to legal.contracts@contoso.com.

Last approved by: Jean-Francois Tremblay, General Counsel - November 30, 2023